VULNERABILITY ASSESSMENT & PENETRATION TEST REPORT

Assessment A-2423efa9

Generated by ARGUS (AI-assisted, evidence-grounded) · assessment A-2423efa9

Authorized scope	10.77.0.0/24
Exclusions	10.77.0.1, 10.77.0.2, 10.77.0.3
Authorized by	Team ARGUS (own isolated lab)
Assessment window	2026-11-02T12:57:44+00:00 to 2026-11-02T13:15:01+00:00 (UTC)
Report status	review; audit chain verified intact

Important. This report was produced by an automated assistant from real tool output. Findings marked *suspected* or *observed* have not been manually verified. Use of the standards named here (NIST SP 800-115, OWASP Top 10, CVE, CVSS, CWE, MITRE ATT&CK, NIST CSF 2.0) is indicative and does not establish formal compliance.

1. Executive Summary

ARGUS assessed 1 authorized target(s) (10.77.0.0/24) and identified **21** distinct finding(s) across 2 host(s), plus 18 informational observation(s) (Appendix E). 2 additional tool alert(s) were investigated and **refuted as false positives**; they are listed in Appendix B and excluded from the risk ranking. 9 finding(s) were independently validated, and 3 were reported independently by more than one tool.

Highest-priority issues (ranked by a transparent score, see section 3): **F-041** SQL Injection on 10.77.0.10:80 (priority 6.8, observed) [EV-0019]; **F-004** Suggested security header missing: content-security-policy. on 10.77.0.10:80 (priority 5.5, validated) [EV-0004] [EV-0005]; **F-017** Missing Anti-clickjacking Header on 10.77.0.10:80 (priority 5.5, validated) [EV-0005] [EV-0015].

Overall assessment. Significant weaknesses were found that warrant prompt remediation.

Scope and rules of engagement. All testing was restricted to the authorized lab scope above. Active or intrusive actions required recorded human approval (section 6).

2. Assessment Methodology

The assessment followed the planning, discovery, attack (validation) and reporting phases of NIST SP 800-115. The agent selected each next action from its current evidence (Decision Cards, Appendix C) rather than a fixed script. Every action passed a deterministic scope check and was written to a hash-chained audit log.

Assets tested

10.77.0.10:80 (http), 10.77.0.11:3000 (http)

Tool execution summary

Job	Tool	Mode	Target	Status	Started	Detail
J-001	nmap	LIVE	10.77.0.0/24	OK	12:57:52	
J-002	nmap	LIVE	10.77.0.10	OK	12:58:22	
J-003	nmap	LIVE	10.77.0.11	OK	12:58:36	
J-004	nikto	LIVE	http://10.77.0.10	OK	12:58:51	
J-007	zap	LIVE	http://10.77.0.10	OK	12:59:02	
J-008	nikto	LIVE	http://10.77.0.11:3000	OK	12:59:22	
J-011	zap	LIVE	http://10.77.0.11:3000	OK	13:01:31	
J-012	argus-http	LIVE	http://10.77.0.10:80/	OK	13:02:11	
J-013	argus-http	LIVE	http://10.77.0.10:80/config/	OK	13:02:13	
J-014	argus-http	LIVE	http://10.77.0.10:80/docs/	OK	13:02:14	
J-015	argus-http	LIVE	http://10.77.0.10:80/	OK	13:02:14	
J-016	argus-http	LIVE	http://10.77.0.10/robots.txt	OK	13:02:14	
J-017	argus-http	LIVE	http://10.77.0.10:80/	OK	13:02:15	
J-018	argus-http	LIVE	http://10.77.0.10	OK	13:02:15	
J-019	argus-http	LIVE	http://10.77.0.10/login.php	OK	13:02:16	
J-020	argus-http	LIVE	http://10.77.0.10	OK	13:02:16	
J-021	argus-http	LIVE	http://10.77.0.11:3000/	OK	13:02:16	
J-022	argus-http	LIVE	http://10.77.0.11:3000/	OK	13:02:17	
J-023	zap	LIVE	http://10.77.0.10	FAILED	13:03:16	ReadTimeout: timed out
J-024	zap	LIVE	http://10.77.0.10	OK	13:08:36	
J-025	argus-http	LIVE	http://10.77.0.11:3000/	OK	13:14:46	

Integration status (truthful)

Tool	Status	Runtime now	Limitations
nmap	LIVE	ready	Requires the argus-tools container. No vulners script: CVE hints come only from a small reference table.
nessus	IMPORT-ONLY	ready	Commercial product; live API integration is not implemented or claimed. Informational plugins are treated as context.
openvas	IMPORT-ONLY	ready	Live GMP integration is Planned (Greenbone community feed sync is heavy); import is supported.
nikto	LIVE	ready	Nikto reports no CVSS and no severity; ARGUS derives a coarse severity from the message and marks it as derived.
zap	LIVE	ready	Needs the argus-zap daemon. ZAP does not provide CVSS scores; none are fabricated.
burp	IMPORT-ONLY	ready	Burp Community has no scanner export/API; Burp Pro REST API integration is Planned, not implemented.
metasploit	LIVE	unavailable: image metasploitframework/metasploit-	Requires the metasploit-framework Docker image (large) and an approved action. Exploit modules are NOT supported by design. Not autonomous.

3. Severity Distribution and Prioritized Findings

Severity (as reported)	Count
CRITICAL	0
HIGH	1
MEDIUM	7
LOW	13
INFO	0

How priority is computed: priority = min(10, base × exposure × exploitability × asset criticality × confidence weight). Base is the CVSS score reported by a tool; when no tool supplies CVSS, the midpoint of the tool-reported severity is used and labelled as such. No CVSS value in this report was generated by ARGUS. The KEV check uses a small, partial offline snapshot.

Rank	ID	Finding	Asset	Sev.	Priority	Status	Conf.
1	F-041	SQL Injection	10.77.0.10:80	HIGH	6.8	observed	40
2	F-004	Suggested security header missing: content-security-policy.	10.77.0.10:80	MEDIUM	5.5	validated	65
3	F-017	Missing Anti-clickjacking Header	10.77.0.10:80	MEDIUM	5.5	validated	40
4	F-031	Suggested security header missing: content-security-policy.	10.77.0.11:3000	MEDIUM	5.5	validated	90
5	F-023	Application Error Disclosure	10.77.0.10:80	MEDIUM	4.7	observed	55
6	F-024	Directory Browsing	10.77.0.10:80	MEDIUM	4.7	observed	55
7	F-038	Cross-Domain Misconfiguration	10.77.0.11:3000	MEDIUM	4.7	observed	55
8	F-040	CSP: Failure to Define Directive with No Fallback	10.77.0.11:3000	MEDIUM	4.7	observed	55
9	F-005	Suggested security header missing: x-content-type-options.	10.77.0.10:80	LOW	2.5	validated	65
10	F-007	Directory indexing found.	10.77.0.10:80	LOW	2.5	validated	90
11	F-009	Directory indexing found.	10.77.0.10:80	LOW	2.5	validated	90
12	F-014	Server Leaks Version Information via "Server" HTTP Response Header Fie	10.77.0.10:80	LOW	2.5	validated	55
13	F-016	Cookie No HttpOnly Flag	10.77.0.10:80	LOW	2.5	validated	55
14	F-019	Cookie without SameSite Attribute	10.77.0.10:80	LOW	2.5	validated	55
15	F-001	Suggested security header missing: referrer-policy.	10.77.0.10:80	LOW	2.1	observed	40
16	F-003	Suggested security header missing: permissions-policy.	10.77.0.10:80	LOW	2.1	observed	40
17	F-006	Apache/2.4.25 appears to be outdated (current is at least 2.4.68).	10.77.0.10:80	LOW	2.1	observed	40
18	F-015	In Page Banner Information Leak	10.77.0.10:80	LOW	2.1	observed	55
19	F-022	Information Disclosure - Debug Error Messages	10.77.0.10:80	LOW	2.1	observed	55
20	F-029	Suggested security header missing: permissions-policy.	10.77.0.11:3000	LOW	2.1	observed	40
21	F-032	Suggested security header missing: referrer-policy.	10.77.0.11:3000	LOW	2.1	observed	40

4. Detailed Vulnerability Findings

F-041 — SQL Injection

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/setup.php Parameter: create_db
Severity / CVSS	**HIGH** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-89 / A03:2021 Injection
MITRE ATT&CK (indicative)	T1190
Validation status	**OBSERVED** · confidence 40/100
Priority	6.8 (rank 1)

OBSERVED (tool evidence): SQL injection may be possible.
Reported by: zap (LIVE) [EV-0019] rule zap:40018

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | zap-confidence:Medium
Risk factors: base 8.0 (no CVSS available; midpoint of 'high' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-004 — Suggested security header missing: content-security-policy.

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/, http://10.77.0.10/sitemap.xml, http://10.77.0.10/setup.php, http://10.77.0.10/login.php
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 65/100 Validation: confirmed by argus-http-check - No Content-Security-Policy header in the response. [EV-0011]
Priority	5.5 (rank 2)

OBSERVED (tool evidence): Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Reported by: nikto (LIVE) [EV-0004] rule nikto:013587, zap (LIVE) [EV-0005] rule zap:10038, zap (LIVE) [EV-0019] rule zap:10038

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-017 — Missing Anti-clickjacking Header

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/login.php, http://10.77.0.10/setup.php, http://10.77.0.10/about.php, http://10.77.0.10/instructions.php Parameter: x-frame-options
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1021 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 40/100 Validation: confirmed by argus-http-check - Neither X-Frame-Options nor a CSP frame-ancestors directive is present in the response. [EV-0015]
Priority	5.5 (rank 3)

OBSERVED (tool evidence): The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
Reported by: zap (LIVE) [EV-0005] rule zap:10020, zap (LIVE) [EV-0019] rule zap:10020

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-031 — Suggested security header missing: content-security-policy.

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000/, http://10.77.0.11:3000/sitemap.xml, http://10.77.0.11:3000, http://10.77.0.11:3000/ftp
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 Validation: confirmed by argus-http-check - No Content-Security-Policy header in the response. [EV-0018]
Priority	5.5 (rank 4)

OBSERVED (tool evidence): Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Reported by: nikto (LIVE) [EV-0006] rule nikto:013587, zap (LIVE) [EV-0007] rule zap:10038

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:High | validation: confirmed by argus-http-check: No Content-Security-Policy header in the response. | retest: still present: No Content-Security-Policy header in the response.
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-023 — Application Error Disclosure

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/dvwa/css/, http://10.77.0.10/docs/, http://10.77.0.10/docs/?C=N;O=D, http://10.77.0.10/dvwa/css/?C=N;O=D
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-550 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100
Priority	4.7 (rank 5)

OBSERVED (tool evidence): This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page. Evidence: HTTP/1.0 500 Internal Server Error
Reported by: zap (LIVE) [EV-0005] rule zap:90022, zap (LIVE) [EV-0019] rule zap:90022

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-024 — Directory Browsing

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/dvwa/css/, http://10.77.0.10/docs/, http://10.77.0.10/docs/?C=N;O=D, http://10.77.0.10/dvwa/css/?C=N;O=D
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-548 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100
Priority	4.7 (rank 6)

OBSERVED (tool evidence): It is possible to view a listing of the directory contents. Directory listings may reveal hidden scripts, include files, backup source files, etc., which can be accessed to reveal sensitive information. Evidence: <title>Index of /dvwa/includes/DBMS</title>
Reported by: zap (LIVE) [EV-0005] rule zap:10033, zap (LIVE) [EV-0019] rule zap:10033

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-038 — Cross-Domain Misconfiguration

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000/robots.txt, http://10.77.0.11:3000/assets/public/favicon_js.ico, http://10.77.0.11:3000/sitemap.xml, http://10.77.0.11:3000
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-264 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100
Priority	4.7 (rank 7)

OBSERVED (tool evidence): Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server. Evidence: Access-Control-Allow-Origin: *
Reported by: zap (LIVE) [EV-0007] rule zap:10098

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-040 — CSP: Failure to Define Directive with No Fallback

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000/assets, http://10.77.0.11:3000/assets/public Parameter: Content-Security-Policy
Severity / CVSS	**MEDIUM** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100
Priority	4.7 (rank 8)

OBSERVED (tool evidence): The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything. Evidence: default-src 'none'
Reported by: zap (LIVE) [EV-0007] rule zap:10055

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-005 — Suggested security header missing: x-content-type-options.

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/, http://10.77.0.10/robots.txt, http://10.77.0.10/favicon.ico, http://10.77.0.10/dvwa/css/login.css
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-693 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 65/100 Validation: confirmed by argus-http-check - X-Content-Type-Options header is absent. [EV-0013]
Priority	2.5 (rank 9)

OBSERVED (tool evidence): The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Reported by: nikto (LIVE) [EV-0004] rule nikto:013587, nikto (LIVE) [EV-0004] rule nikto:007352, zap (LIVE) [EV-0005] rule zap:10021, zap (LIVE) [EV-0019] rule zap:10021

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-007 — Directory indexing found.

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/config/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-548 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 Validation: confirmed by argus-http-check - The response is an auto-generated directory index ('Index of /'). [EV-0009]
Priority	2.5 (rank 10)

OBSERVED (tool evidence): Nikto test 750500 (GET /config/): Directory indexing found.
Reported by: nikto (LIVE) [EV-0004] rule nikto:750500

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | validation: confirmed by argus-http-check: The response is an auto-generated directory index ('Index of /').
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-009 — Directory indexing found.

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/docs/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-548 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 90/100 Validation: confirmed by argus-http-check - The response is an auto-generated directory index ('Index of /'). [EV-0010]
Priority	2.5 (rank 11)

OBSERVED (tool evidence): Nikto test 750500 (GET /docs/): Directory indexing found.
Reported by: nikto (LIVE) [EV-0004] rule nikto:750500

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | validation: confirmed by argus-http-check: The response is an auto-generated directory index ('Index of /').
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-014 — Server Leaks Version Information via "Server" HTTP Response Header Field

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/robots.txt, http://10.77.0.10/, http://10.77.0.10/sitemap.xml, http://10.77.0.10/dvwa/images/login_logo.png
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-497 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 55/100 Validation: confirmed by argus-http-check - Response discloses software version: 'Apache/2.4.25 (Debian)'. [EV-0012]
Priority	2.5 (rank 12)

OBSERVED (tool evidence): The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
Evidence: Apache/2.4.25 (Debian)
Reported by: zap (LIVE) [EV-0005] rule zap:10036, zap (LIVE) [EV-0019] rule zap:10036

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-016 — Cookie No HttpOnly Flag

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10, http://10.77.0.10/about.php, http://10.77.0.10/, http://10.77.0.10/instructions.php?doc=copying Parameter: PHPSESSID
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1004 / A05:2021 Security Misconfiguration
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 55/100 Validation: confirmed by argus-http-check - Cookie(s) PHPSESSID, PHPSESSID, security lack the httponly attribute. [EV-0014]
Priority	2.5 (rank 13)

OBSERVED (tool evidence): A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible. Evidence: Set-Cookie: PHPSESSID
Reported by: zap (LIVE) [EV-0005] rule zap:10010, zap (LIVE) [EV-0019] rule zap:10010

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-019 — Cookie without SameSite Attribute

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10, http://10.77.0.10/about.php, http://10.77.0.10/, http://10.77.0.10/login.php Parameter: PHPSESSID
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1275 / A01:2021 Broken Access Control
MITRE ATT&CK (indicative)	n/a
Validation status	**VALIDATED** · confidence 55/100 Validation: confirmed by argus-http-check - Cookie(s) PHPSESSID, PHPSESSID, security lack the samesite attribute. [EV-0016]
Priority	2.5 (rank 14)

OBSERVED (tool evidence): A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks. Evidence: Set-Cookie: PHPSESSID
Reported by: zap (LIVE) [EV-0005] rule zap:10054, zap (LIVE) [EV-0019] rule zap:10054

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

F-001 — Suggested security header missing: referrer-policy.

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 40/100
Priority	2.1 (rank 15)

OBSERVED (tool evidence): Nikto test 013587 (GET /): Suggested security header missing: referrer-policy.
Reported by: nikto (LIVE) [EV-0004] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-003 — Suggested security header missing: permissions-policy.

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 40/100
Priority	2.1 (rank 16)

OBSERVED (tool evidence): Nikto test 013587 (GET /): Suggested security header missing: permissions-policy.
Reported by: nikto (LIVE) [EV-0004] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-006 — Apache/2.4.25 appears to be outdated (current is at least 2.4.68).

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10:80/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1104 / A06:2021 Vulnerable and Outdated Components
MITRE ATT&CK (indicative)	T1190
Validation status	**OBSERVED** · confidence 40/100
Priority	2.1 (rank 17)

OBSERVED (tool evidence): Nikto test 600050 (HEAD /): Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
Reported by: nikto (LIVE) [EV-0004] rule nikto:600050

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-015 — In Page Banner Information Leak

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/sitemap.xml, http://10.77.0.10/var/www/html/config/config.inc.php, http://10.77.0.10/var/www, http://10.77.0.10/var
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-497 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100
Priority	2.1 (rank 18)

OBSERVED (tool evidence): The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use. Evidence: Apache/2.4.25
Reported by: zap (LIVE) [EV-0005] rule zap:10009, zap (LIVE) [EV-0019] rule zap:10009

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-022 — Information Disclosure - Debug Error Messages

Affected asset	10.77.0.10:80 URLs: http://10.77.0.10/instructions.php, http://10.77.0.10/instructions.php?doc=readme
Severity / CVSS	**LOW** (reported by zap) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / CWE-1295 / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 55/100
Priority	2.1 (rank 19)

OBSERVED (tool evidence): The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages. Evidence: PHP warning
Reported by: zap (LIVE) [EV-0005] rule zap:10023, zap (LIVE) [EV-0019] rule zap:10023

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-029 — Suggested security header missing: permissions-policy.

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 40/100
Priority	2.1 (rank 20)

OBSERVED (tool evidence): Nikto test 013587 (GET /): Suggested security header missing: permissions-policy.
Reported by: nikto (LIVE) [EV-0006] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

F-032 — Suggested security header missing: referrer-policy.

Affected asset	10.77.0.11:3000 URLs: http://10.77.0.11:3000/
Severity / CVSS	**LOW** (reported by derived from nikto message) · CVSS: not provided by any tool
CVE / CWE / OWASP	none reported / n/a / n/a
MITRE ATT&CK (indicative)	n/a
Validation status	**OBSERVED** · confidence 40/100
Priority	2.1 (rank 21)

OBSERVED (tool evidence): Nikto test 013587 (GET /): Suggested security header missing: referrer-policy.
Reported by: nikto (LIVE) [EV-0006] rule nikto:013587

ANALYSIS (rule-based inference): Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

5. Impact and Remediation

ID	Technical / business impact	Recommended remediation	References
F-041	Data theft or modification, potential full database compromise.	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application.	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
F-004	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Define a restrictive Content-Security-Policy appropriate for the application.	https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html; https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
F-017	Users can be tricked into clicking hidden UI; may enable unwanted actions in an authenticated session.	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
F-031	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Define a restrictive Content-Security-Policy appropriate for the application.	https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html; https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
F-023	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.	CWE-550

ID	Technical / business impact	Recommended remediation	References
F-024	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Configure the web server to disable directory browsing.	https://cwe.mitre.org/data/definitions/548.html
F-038	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
F-040	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.	https://caniuse.com/#search=content+security+policy; https://content-security-policy.com/
F-005	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Send 'X-Content-Type-Options: nosniff' on all responses.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options; https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
F-007	Reveals file structure and potentially sensitive files to anyone.	Disable automatic directory indexing (e.g. 'Options -Indexes' in Apache).	CWE-548
F-009	Reveals file structure and potentially sensitive files to anyone.	Disable automatic directory indexing (e.g. 'Options -Indexes' in Apache).	CWE-548
F-014	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.	https://httpd.apache.org/docs/current/mod/core.html#servertokens; https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
F-016	Script (e.g. via XSS) can read the session cookie, enabling account takeover.	Ensure that the HttpOnly flag is set for all cookies.	https://owasp.org/www-community/HttpOnly
F-019	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
F-001	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	See tool guidance; no automated recommendation available.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
F-003	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	See tool guidance; no automated recommendation available.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
F-006	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Upgrade to a currently supported release and apply vendor security updates.	CWE-1104

ID	Technical / business impact	Recommended remediation	References
F-015	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/
F-022	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	Disable debugging messages before pushing to production.	CWE-1295
F-029	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	See tool guidance; no automated recommendation available.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
F-032	Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess).	See tool guidance; no automated recommendation available.	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy

6. Assessment Limitations, Assumptions and Human Approvals

• zap (zap_active) on http://10.77.0.10 did not complete: RuntimeError: ReadTimeout: timed out. Coverage for this check is missing.
• Findings are limited to what the integrated tools could observe; absence of a finding is not proof of absence.
• Exposure is assumed to be 'reachable over the network without authentication' for all lab assets; asset criticality defaulted to 1.0 unless set by the analyst.
• The CISA KEV check uses a small partial offline snapshot; CVE-to-version mapping uses a small reference table.

Human approvals (active validation)

ID	Action	Status	Decided by	Decided at	Comment / outcome
AP-001	zap_active:http://10.77.0.10	FAILED	Rahul	2026-11-02T13:03:16	Lab DVWA only, approved for demo / execution failed or tool unavailable; see assessment limitations
AP-002	zap_active:http://10.77.0.10	EXECUTED	Rahul	2026-11-02T13:08:36	Retry after ZAP API timeout fix; lab DVWA only / executed: 244 raw finding(s); ZAP discovered 65 URLs; active

Assessment timestamps: first audit event 2026-11-02T12:57:44+00:00, last 2026-11-02T13:15:01+00:00 (UTC).

Appendix A. Evidence index (traceability)

Every finding ID above links to evidence IDs here. Each file's SHA-256 was computed when it was captured; the raw file is available in the ARGUS data folder.

Evidence	Tool	Mode	Captured (UTC)	File	SHA-256	Locator
EV-0001	nmap	LIVE	2026-11-02T12:58:14	artifacts/A-2423efa9/J-001_nmap.xml	94ab61ffa6451d06...	nmaprun
EV-0002	nmap	LIVE	2026-11-02T12:58:31	artifacts/A-2423efa9/J-002_nmap.xml	bf37e448e5bb0a89...	nmaprun
EV-0003	nmap	LIVE	2026-11-02T12:58:48	artifacts/A-2423efa9/J-003_nmap.xml	e09c0700527ee4aa...	nmaprun
EV-0004	nikto	LIVE	2026-11-02T12:59:01	rtifacts/A-2423efa9/J-004_nikto.json	1f3420e09028ece8...	$.vulnerabilities
EV-0005	zap	LIVE	2026-11-02T12:59:18	artifacts/A-2423efa9/J-007_zap.json	6cbd3cc07fbb6d5c...	$.alerts
EV-0006	nikto	LIVE	2026-11-02T13:01:28	rtifacts/A-2423efa9/J-008_nikto.json	f975236245517f2e...	$.vulnerabilities
EV-0007	zap	LIVE	2026-11-02T13:02:08	artifacts/A-2423efa9/J-011_zap.json	4d264a2f77de4d57...	$.alerts
EV-0008	argus-http-check	LIVE	2026-11-02T13:02:13	ifacts/A-2423efa9/J-012_validate.txt	86c2c2a59eff09b3...	response headers
EV-0009	argus-http-check	LIVE	2026-11-02T13:02:14	ifacts/A-2423efa9/J-013_validate.txt	1b1ea6f935dceb42...	response headers
EV-0010	argus-http-check	LIVE	2026-11-02T13:02:14	ifacts/A-2423efa9/J-014_validate.txt	5e63ce00cd7d472d...	response headers
EV-0011	argus-http-check	LIVE	2026-11-02T13:02:14	ifacts/A-2423efa9/J-015_validate.txt	f40658e92b369e17...	response headers
EV-0012	argus-http-check	LIVE	2026-11-02T13:02:15	ifacts/A-2423efa9/J-016_validate.txt	99bc0f7571027a1b...	response headers
EV-0013	argus-http-check	LIVE	2026-11-02T13:02:15	ifacts/A-2423efa9/J-017_validate.txt	ac8af73e515fb3b9...	response headers
EV-0014	argus-http-check	LIVE	2026-11-02T13:02:15	ifacts/A-2423efa9/J-018_validate.txt	6af977a4d3bf2719...	response headers
EV-0015	argus-http-check	LIVE	2026-11-02T13:02:16	ifacts/A-2423efa9/J-019_validate.txt	b97e1f7f9f28ea90...	response headers
EV-0016	argus-http-check	LIVE	2026-11-02T13:02:16	ifacts/A-2423efa9/J-020_validate.txt	d02152263828110d...	response headers
EV-0017	argus-http-check	LIVE	2026-11-02T13:02:17	ifacts/A-2423efa9/J-021_validate.txt	68c7b73a57f4836b...	response headers
EV-0018	argus-http-check	LIVE	2026-11-02T13:02:17	ifacts/A-2423efa9/J-022_validate.txt	68c7b73a57f4836b...	response headers
EV-0019	zap	LIVE	2026-11-02T13:13:51	artifacts/A-2423efa9/J-024_zap.json	97d6e9a0272e0ad8...	$.alerts
EV-0020	argus-http-check	LIVE	2026-11-02T13:14:49	rtifacts/A-2423efa9/J-025_retest.txt	94dfb21e6c80c989...	response headers

Appendix B. Refuted alerts (false positives)

ID	Alert	Asset	Why refuted	Evidence
F-002	Suggested security header missing: strict-transport-security	10.77.0.10:80	The service is plain HTTP. Browsers ignore Strict-Transport-Security on HTTP, so this check does not apply until HTTPS is enabled.	EV-0004, EV-0008
F-030	Suggested security header missing: strict-transport-security	10.77.0.11:3000	The service is plain HTTP. Browsers ignore Strict-Transport-Security on HTTP, so this check does not apply until HTTPS is enabled.	EV-0006, EV-0017

Appendix C. Agent decision log

D-001 [scope] planner: rules · chose: nmap_scan:10.77.0.0/24
Reasoning: No hosts or services are known yet. Service discovery is the prerequisite for choosing every other tool.
Scope check: 10.77.0.0/24: in scope
Outcome: pending

D-002 [recon] planner: rules · chose: nmap_scan:10.77.0.0/24
Reasoning: No hosts or services are known yet. Service discovery is the prerequisite for choosing every other tool.
Scope check: nmap/standard on 10.77.0.0/24 allowed
Outcome: completed: 0 raw finding(s), total findings 0 -> 0

D-003 [enumeration] planner: rules · chose: nmap_enum:10.77.0.10
Reasoning: HTTP found on 10.77.0.10 port(s) [80]: NSE http scripts reveal titles, methods and common paths cheaply before heavier scans.
Scope check: nmap/standard on 10.77.0.10 allowed
Outcome: completed: 0 raw finding(s), total findings 0 -> 0

D-004 [enumeration] planner: rules · chose: nmap_enum:10.77.0.11
Reasoning: HTTP found on 10.77.0.11 port(s) [3000]: NSE http scripts reveal titles, methods and common paths cheaply before heavier scans.
Scope check: nmap/standard on 10.77.0.11 allowed
Outcome: completed: 0 raw finding(s), total findings 0 -> 0

D-005 [vulnerability-analysis] planner: rules · chose: nikto:http://10.77.0.10
Reasoning: http://10.77.0.10 serves HTTP: Nikto checks server configuration and known files; complements ZAP, and a second tool lets findings be cross-checked.
Scope check: nikto/standard on 10.77.0.10 allowed
Outcome: completed: 14 raw finding(s), total findings 0 -> 13

D-006 [vulnerability-analysis] planner: rules · chose: zap_passive:http://10.77.0.10
Reasoning: http://10.77.0.10 is a web application: ZAP spider + passive analysis maps the app and flags headers, cookies and forms without sending attack payloads.
Scope check: zap/standard on 10.77.0.10 allowed
Outcome: completed: 237 raw finding(s), total findings 13 -> 24

D-007 [vulnerability-analysis] planner: rules · chose: nikto:http://10.77.0.11:3000
Reasoning: http://10.77.0.11:3000 serves HTTP: Nikto checks server configuration and known files; complements ZAP, and a second tool lets findings be cross-checked.
Scope check: nikto/standard on 10.77.0.11 allowed
Outcome: completed: 28 raw finding(s), total findings 24 -> 37

D-008 [vulnerability-analysis] planner: rules · chose: zap_passive:http://10.77.0.11:3000
Reasoning: http://10.77.0.11:3000 is a web application: ZAP spider + passive analysis maps the app and flags headers, cookies and forms without sending attack payloads.
Scope check: zap/standard on 10.77.0.11 allowed
Outcome: completed: 500 raw finding(s), total findings 37 -> 40

D-009 [triage] planner: rules · chose: validate:F-002, validate:F-007, validate:F-009, validate:F-004, validate:F-014, validate:F-005, validate:F-016, validate:F-017, validate:F-019, validate:F-030, validate:F-031
Reasoning: 11 configuration findings can each be confirmed or refuted with one harmless GET. Doing this before ranking removes false positives so they do not distort priorities.
Scope check: nmap/standard on 10.77.0.10 allowed
Outcome: validation verdicts: F-002: refuted; F-007: confirmed; F-009: confirmed; F-004: confirmed; F-014: confirmed; F-005: confirmed; F-016: confirmed; F-017: confirmed; F-019: confirmed; F-030: refuted; F-031: confirmed

Appendix E. Informational observations

Items reported by tools at informational level. They are context, not vulnerabilities, and are not ranked.

ID	Observation	Asset	Source	Evidence
F-008	Configuration information may be available remotely.	10.77.0.10:80	nikto	EV-0004
F-010	Apache default file found.	10.77.0.10:80	nikto	EV-0004
F-011	Admin login page/section found.	10.77.0.10:80	nikto	EV-0004
F-012	.gitignore file found. It is possible to grasp the directory structure.	10.77.0.10:80	nikto	EV-0004
F-013	X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTT	10.77.0.10:80	nikto	EV-0004
F-018	Authentication Request Identified	10.77.0.10:80	zap	EV-0005, EV-0019
F-020	Information Disclosure - Suspicious Comments	10.77.0.10:80	zap	EV-0005, EV-0019
F-021	Session Management Response Identified	10.77.0.10:80	zap	EV-0005, EV-0019
F-025	Retrieved access-control-allow-origin header: *.	10.77.0.11:3000	nikto	EV-0006
F-026	Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.	10.77.0.11:3000	nikto	EV-0006
F-027	/robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200).	10.77.0.11:3000	nikto	EV-0006
F-028	contains 1 entry which should be manually viewed.	10.77.0.11:3000	nikto	EV-0006
F-033	This might be interesting.	10.77.0.11:3000	nikto	EV-0006
F-034	Contains authorization information.	10.77.0.11:3000	nikto	EV-0006
F-035	A user's home directory may be set to the web root, the shell history was retrieved. This	10.77.0.11:3000	nikto	EV-0006
F-036	Database SQL?.	10.77.0.11:3000	nikto	EV-0006
F-037	JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier cont	10.77.0.11:3000	nikto	EV-0006
F-039	Modern Web Application	10.77.0.11:3000	zap	EV-0007

Appendix D. Audit trail (hash-chained)

Chain verification: INTACT.

#	Time (UTC)	Actor	Action	Hash
53	2026-11-02T12:57:44	analyst	assessment.create	b36019a97a80cc
54	2026-11-02T12:57:44	scope-guard	scope.check	e1595730ce0cb2
55	2026-11-02T12:57:49	agent	plan.proposed	d717702415223a
56	2026-11-02T12:57:51	analyst	plan.approved	c26a805efb7ac5
57	2026-11-02T12:57:52	agent	decision	d443beb67b57d9
58	2026-11-02T12:57:52	agent	action.start	40c9461f0840c0
59	2026-11-02T12:58:15	agent	action.done	86fd9d1c1b618d
60	2026-11-02T12:58:22	agent	decision	3d1d65be267350
61	2026-11-02T12:58:22	agent	action.start	250ab0e05b1919
62	2026-11-02T12:58:31	agent	action.done	4462aa574c324a
63	2026-11-02T12:58:35	agent	decision	e2e7f3b1cec561
64	2026-11-02T12:58:35	agent	action.start	d94f19525f2c4f
65	2026-11-02T12:58:48	agent	action.done	21985676006d22
66	2026-11-02T12:58:51	agent	decision	538095506a70d8
67	2026-11-02T12:58:51	agent	action.start	35d32629ca4293
68	2026-11-02T12:59:02	agent	action.done	ac0fccbe44a72f
69	2026-11-02T12:59:02	agent	decision	15a1ff009bdb4f
70	2026-11-02T12:59:02	agent	action.start	09356b2d650e14
71	2026-11-02T12:59:18	agent	action.done	99ad71d1387c93
72	2026-11-02T12:59:22	agent	decision	3fd2ce8b1cbf1a
73	2026-11-02T12:59:22	agent	action.start	3c2272e8f91ae9
74	2026-11-02T13:01:29	agent	action.done	9110fe35749dae
75	2026-11-02T13:01:31	agent	decision	ef2658ce97e9ef
76	2026-11-02T13:01:31	agent	action.start	1d885e7ff669e5
77	2026-11-02T13:02:08	agent	action.done	471306b76c6373
78	2026-11-02T13:02:11	agent	decision	42ac820c9e20e5
79	2026-11-02T13:02:11	agent	action.start	6f878e94d514f2
80	2026-11-02T13:02:13	agent	action.done	2e26a298895b81
81	2026-11-02T13:02:13	agent	action.start	2f39f824ff65cf
82	2026-11-02T13:02:14	agent	action.done	144e7ca6960b3c
83	2026-11-02T13:02:14	agent	action.start	1d28ba97960429
84	2026-11-02T13:02:14	agent	action.done	d05a5bd1131567
85	2026-11-02T13:02:14	agent	action.start	1b6f3d594b6b06
86	2026-11-02T13:02:14	agent	action.done	2cc597921ce542
87	2026-11-02T13:02:14	agent	action.start	47bcc166988658
88	2026-11-02T13:02:15	agent	action.done	034cdd8e01b9d6
89	2026-11-02T13:02:15	agent	action.start	91bae86db0a735
90	2026-11-02T13:02:15	agent	action.done	6918aa9d6bfa02

#	Time (UTC)	Actor	Action	Hash
91	2026-11-02T13:02:15	agent	action.start	dc5e70a5262e84
92	2026-11-02T13:02:16	agent	action.done	cf36ed40770863
93	2026-11-02T13:02:16	agent	action.start	6cabfa210a2394
94	2026-11-02T13:02:16	agent	action.done	076f119025a55c
95	2026-11-02T13:02:16	agent	action.start	85963d0206e167
96	2026-11-02T13:02:16	agent	action.done	d58ad5b919aa2f
97	2026-11-02T13:02:16	agent	action.start	42cfc328c84183
98	2026-11-02T13:02:17	agent	action.done	0135571f82537e
99	2026-11-02T13:02:17	agent	action.start	368c594f209f23
100	2026-11-02T13:02:17	agent	action.done	e36ab6dd2c254b
101	2026-11-02T13:02:23	agent	approval.requested	82ad4fe4b05744
102	2026-11-02T13:02:23	agent	assessment.ready-for-review	837a16b6e696af
103	2026-11-02T13:02:48	analyst	report.download	a82231c03fdc20
104	2026-11-02T13:03:16	Rahul	approval.approved	60d6a4732fa5d9
105	2026-11-02T13:03:16	Rahul(approved)	action.start	b84d39bbd1c65d
106	2026-11-02T13:06:01	agent	action.failed	2d3257e9a498a8
107	2026-11-02T13:06:01	agent	approval.outcome	d92f88de863f52
108	2026-11-02T13:06:23	agent	assessment.ready-for-review	2abb94ae549dbd
109	2026-11-02T13:08:34	analyst	approval.re-requested	cd1770c675142f
110	2026-11-02T13:08:36	Rahul	approval.approved	f8dbcfc49d6e83
111	2026-11-02T13:08:36	Rahul(approved)	action.start	0f2929f368de00
112	2026-11-02T13:13:51	Rahul(approved)	action.done	6fe80fc1b65263
113	2026-11-02T13:13:52	agent	approval.outcome	12e90d344fc3c0
114	2026-11-02T13:13:59	agent	assessment.ready-for-review	489a762cc2ad92
115	2026-11-02T13:14:49	analyst	retest	527d211849745f
116	2026-11-02T13:15:01	analyst	report.download	098edf3bbd1dd2